VULNERABILITY ASSESSMENT REPORT

Security Risk Evaluation & Remediation Plan

Standard: NIST SP 800-30 Rev. 1
Role: Cybersecurity Analyst
Target: Remote Database Server

1. PURPOSE

The purpose of this vulnerability assessment is to evaluate the critical security risks associated with the company's remote database server, which has remained publicly accessible for three years. This database server is a vital corporate asset, as distributed remote staff rely on it continuously to query customer leads and maintain business operations. Securing this asset is paramount to preventing catastrophic data exfiltration, regulatory non-compliance penalties, and significant financial loss. If compromised or rendered unavailable, the disruption would halt lead generation and critically undermine customer trust and organizational viability.

2. RISK ASSESSMENT TABLE

Threat Source	Threat Event	Likelihood (1–3)	Severity (1–3)	Risk Score (1–9)
External Attacker (Malicious Hacker)	Exploiting open, publicly exposed database ports to exfiltrate and compromise confidential customer data.	**3**	**3**	**9 (Critical)**
Competitor / Hostile Actor (Adversarial Entity)	Launching a Distributed Denial of Service (DDoS) attack to disrupt server availability and paralyze lead queries.	**3**	**2**	**6 (High)**
Remote Employee (Human Error / Compromised Account)	Accidental deletion, unauthorized modification, or exposure of customer records due to unmanaged global access privileges.	**2**	**3**	**6 (High)**

** Risk Score calculation: Risk = Likelihood × Severity (Scale: 1–9).*

3. APPROACH

A qualitative risk assessment methodology was conducted in alignment with the NIST SP 800-30 Rev. 1 framework to evaluate likelihood and organizational impact. The three threat sources were prioritized because exposing a core database server directly to the public Internet drastically expands the attack surface, inviting continuous automated reconnaissance, vulnerability exploitation, and service disruption. External malicious actors present immediate risks of data theft and public exposure, whereas competitors could intentionally compromise system availability to degrade our market advantage. Furthermore, remote employees connecting globally without centralized identity enforcement present severe risks of credential theft and operational errors.

4. REMEDIATION & MITIGATION STRATEGY

To remediate these vulnerabilities, the database server must immediately be removed from public exposure and isolated behind a secure firewall, restricting inbound access exclusively through an encrypted Virtual Private Network (VPN). We must enforce the Principle of Least Privilege and Role-Based Access Control (RBAC) under the AAA framework (Authentication, Authorization, and Accounting) to ensure employees access only necessary data. Mandatory Multi-Factor Authentication (MFA) must be deployed across all remote connections to prevent unauthorized access via compromised credentials. Finally, applying Defense in Depth—including end-to-end database encryption at rest and in transit (TLS)—will ensure long-term confidentiality, integrity, and availability.